

Reflection Questions & Answers

Q1. Explain the difference between authentication and authorization.

Ans: Authentication is the process of verifying who a user is. It checks user identity using credentials such as usernames and hashed passwords, tokens, or biometric data (eg. verifying that a client logging in with username "alice" actually knows Alice's password).

Whereas, Authorization is the process of verifying what permissions or actions an authenticated user is allowed to perform. It determines access rights to specific resources, functions, or data (eg. granting "alice" permission to send private messages or access admin commands while restricting standard users).

Q2. Why should passwords never be stored in plain text?

Ans: Passwords must never be stored in plain text because if the database, server, or configuration files are compromised via an attack instantly gains full access to every user's actual password.

Furthermore, because users frequently reuse passwords across multiple services, a plain-text database leak exposes their accounts on external platforms (credentials stuffing attacks), creating severe security and privacy risks.

Q3. What is the purpose of password hashing?

Ans:- Password hashing transforms plain-text passwords into fixed-length, irreversible cryptographic strings before saving them.

- One-Way Protection: Passwords cannot be decrypted back into plain text. The server verifies logins by hashing input passwords and comparing the results.
- Breach Protection: If the server database is leaked, attackers only get useless cryptographic hashes instead of actual passwords.

Q4. How does duplicate login prevention improve security?

Ans:- It blocks a single user account from having multiple active sessions at the same time.

- Prevent Account Hijacking: Stops an attacker from using stolen credentials if the real user is already logged in.

- Protect Account Integrity: Prevents conflicting real-time actions and unauthorized impersonation on active accounts.
- Detects Suspicious Activity: Alerts users if someone else tries to access their active account.

85. Suggest two additional security improvements for your application.

Ans:- (a) Transport Layer Encryption (TLS/SSL): Encrypts raw TCP sockets to shield messages and credentials from eavesdropping or packet sniffing (e.g., using WireShark).

(b) Salted Password Hashing (bcrypt/PBKDF2): Adds a unique random "salt" to each password before hashing, preventing attackers from using Rainbow Tables to crack passwords.